



Fortify Audit Workbench

SANS Top 25 2011

Fortifymvp



Table of Contents

[Executive Summary](#)

[Project Description](#)

[Issue Breakdown](#)

[Issue Details](#)

[Risky Resource Management - CWE ID 022](#)

[Insecure Interaction - CWE ID 078](#)

[Insecure Interaction - CWE ID 079](#)

[Insecure Interaction - CWE ID 089](#)

[Risky Resource Management - CWE ID 120](#)

[Risky Resource Management - CWE ID 131](#)

[Risky Resource Management - CWE ID 134](#)

[Risky Resource Management - CWE ID 190](#)

[Porous Defenses - CWE ID 250](#)

[Porous Defenses - CWE ID 306](#)

[Porous Defenses - CWE ID 307](#)

[Porous Defenses - CWE ID 311](#)

[Porous Defenses - CWE ID 327](#)

[Insecure Interaction - CWE ID 352](#)

[Insecure Interaction - CWE ID 434](#)

[Risky Resource Management - CWE ID 494](#)

[Insecure Interaction - CWE ID 601](#)

[Risky Resource Management - CWE ID 676](#)

[Porous Defenses - CWE ID 732](#)

[Porous Defenses - CWE ID 759](#)

[Porous Defenses - CWE ID 798](#)

[Porous Defenses - CWE ID 807](#)

[Risky Resource Management - CWE ID 829](#)

[Porous Defenses - CWE ID 862](#)

[Porous Defenses - CWE ID 863](#)

[Description of Key Terminology](#)

[About Fortify Solutions](#)

© Copyright 2008-2026 Open Text. The only warranties for products and services of Open Text and its affiliates and licensors ("Open Text") are as may be set forth in the express warranty statements accompanying such products and services. Nothing herein should be construed as constituting an additional warranty. Open Text shall not be liable for technical or editorial errors or omissions contained herein. The information contained herein is subject to change without notice.

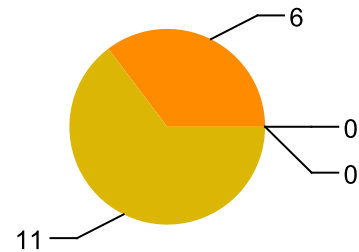


Executive Summary

「SANS Top 25 2011 Most Dangerous Software Errors」列舉了會在軟體中導致嚴重弱點的最廣泛、最嚴重的錯誤，依 Common Weakness Enumeration (CWE) 識別碼分類 (<http://cwe.mitre.org/>)。這些錯誤通常易於尋找與利用。這些錯誤中的內在危險在於，可以允許攻擊者完全接管軟體、竊取資料或讓軟體完全停止運作。

Project Name: Fortifymvp
Project Version:
SCA: Results Present
WebInspect: Results Not Present
WebInspect Agent: Results Not Present
Other: Results Not Present

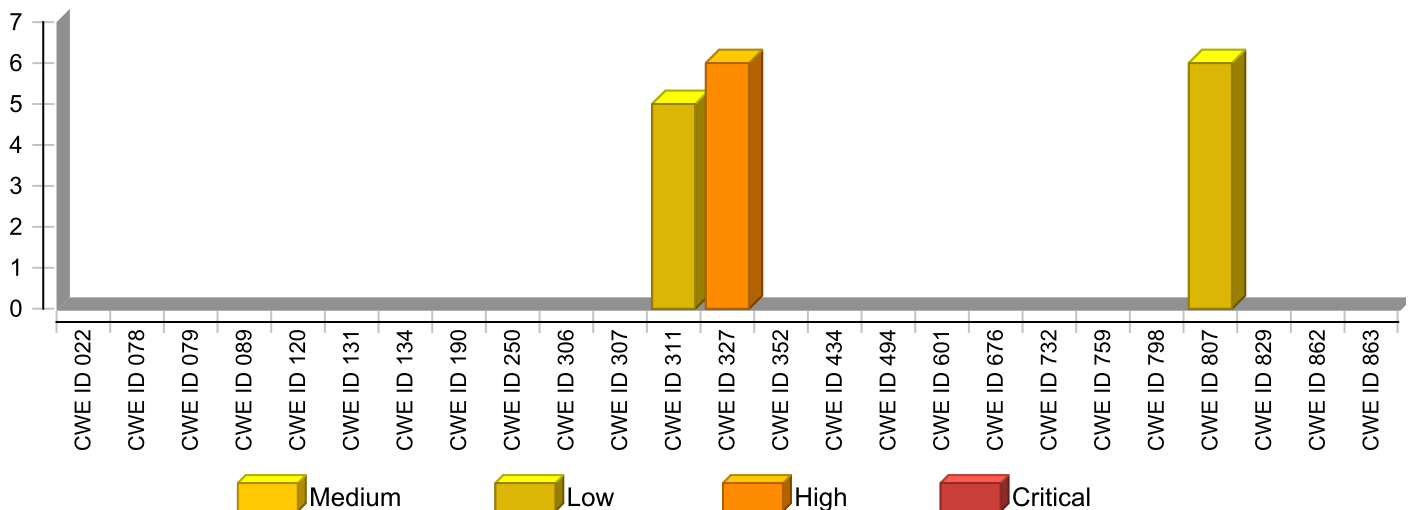
Issues by Folder



SANS Top 25 2011 groups

	Total	Status
Insecure Interaction	0	PASS
Porous Defenses	17	FAIL
Risky Resource Management	0	PASS

Issues by SANS Top 25 2011 Categories



* The detailed sections following the Executive Summary contain specifics.



Project Description

This section provides an overview of the Fortify scan engines used for this project, as well as the project meta-information.

SCA

Date of Last Analysis:	2026年7月7日 上午11:00	Engine Version:	26.2.0.0071
Host Name:	TPEBNKSCAAP10TT	Certification:	VALID
Number of Files:	20	Lines of Code:	6,586
Rulepack Name		Rulepack Version	
Fortify 安全編碼規則、社群、Cloud		2026.2.1.0001	
Fortify 安全編碼規則、社群、Universal		2026.2.1.0001	
Fortify 安全編碼規則、核心、Android		2026.2.1.0001	
Fortify 安全編碼規則、核心、Annotations		2026.2.1.0001	
Fortify 安全編碼規則、核心、Cloud		2026.2.1.0001	
Fortify 安全編碼規則、核心、Java		2026.2.1.0001	
Fortify 安全編碼規則、核心、Universal		2026.2.1.0001	
Fortify 安全編碼規則、延伸、配置		2026.2.1.0001	
Fortify 安全編碼規則、延伸、內容		2026.2.1.0001	
Fortify 安全編碼規則、延伸、Java		2026.2.1.0001	
Fortify 安全編碼規則、延伸、JSP		2026.2.1.0001	



Issue Breakdown

The following table summarizes the number of issues identified across the different SANS Top 25 2011 categories and broken down by Fortify Priority Order.

Risky Resource Management	Folder	Issues	Audited
Risky Resource Management - CWE ID 022		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Insecure Interaction	Folder	Issues	Audited
Insecure Interaction - CWE ID 078		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Insecure Interaction - CWE ID 079		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Insecure Interaction - CWE ID 089		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Risky Resource Management	Folder	Issues	Audited
Risky Resource Management - CWE ID 120		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Risky Resource Management - CWE ID 131		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Risky Resource Management - CWE ID 134		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Risky Resource Management - CWE ID 190		0	0
	Critical	0	0
	High	0	0



Risky Resource Management	Folder	Issues	Audited
Risky Resource Management - CWE ID 190		0	0
	Medium	0	0
	Low	0	0
Porous Defenses	Folder	Issues	Audited
Porous Defenses - CWE ID 250		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Porous Defenses - CWE ID 306		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Porous Defenses - CWE ID 307		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Porous Defenses - CWE ID 311		5	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	5	0
Porous Defenses - CWE ID 327		6	0
	Critical	0	0
	High	6	0
	Medium	0	0
	Low	0	0
Insecure Interaction	Folder	Issues	Audited
Insecure Interaction - CWE ID 352		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Insecure Interaction - CWE ID 434		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Risky Resource Management	Folder	Issues	Audited
Risky Resource Management - CWE ID 494		0	0
	Critical	0	0



Risky Resource Management	Folder	Issues	Audited
Risky Resource Management - CWE ID 494		0	0
	High	0	0
	Medium	0	0
	Low	0	0
Insecure Interaction	Folder	Issues	Audited
Insecure Interaction - CWE ID 601		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Risky Resource Management	Folder	Issues	Audited
Risky Resource Management - CWE ID 676		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Porous Defenses	Folder	Issues	Audited
Porous Defenses - CWE ID 732		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Porous Defenses - CWE ID 759		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Porous Defenses - CWE ID 798		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Porous Defenses - CWE ID 807		6	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	6	0
Risky Resource Management	Folder	Issues	Audited
Risky Resource Management - CWE ID 829		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0



Porous Defenses	Folder	Issues	Audited
Porous Defenses - CWE ID 862		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0
Porous Defenses - CWE ID 863		0	0
	Critical	0	0
	High	0	0
	Medium	0	0
	Low	0	0

NOTE:

1. Reported issues in the above table may violate more than one SANS Top 25 2011 category. As such, the same issue may appear in more than one row. The total number of unique vulnerabilities are reported in the Executive Summary table.



Issue Details

Below is an enumeration of all issues found in the project. The issues are organized by SANS Top 25 2011, Folder, and vulnerability category. The issues are then further broken down by the package, namespace, or location in which they occur. Issues reported at the same line number with the same category originate from different taint sources.

Risky Resource Management - CWE ID 022

不正確地將路徑名稱限制在受限制的目錄範圍內 (「路徑穿越」)。CWE-22 稱：「軟體使用外部輸入來構建旨在識別所限制父系目錄下之檔案或目錄的路徑名稱，但是軟體並未正確抵消路徑名稱中的特殊元素，這些特殊元素會導致將路徑名稱解析為所限制目錄之外的位置。」

No Issues

Insecure Interaction - CWE ID 078

不正確地抵消 OS 指令中所用的特殊元素 (「OS Command Injection」)。CWE-78 稱：「軟體使用源自上游元件之外部影響的輸入構建全部或部分 OS 指令，但是並未抵消或不正確地抵消了特殊元素，導致將預期的 OS 指令傳送至下游元件時，這些特殊元素會修改預期的 OS 指令。」

No Issues

Insecure Interaction - CWE ID 079

在產生網頁期間不正確地抵消輸入 (「Cross-site scripting」)。CWE-79 稱：「軟體並未抵消或不正確地抵消了使用者可以控制的輸入，然後將該輸入置於用作為其他使用者提供之網頁的輸出中。」

No Issues

Insecure Interaction - CWE ID 089

不正確地抵消 SQL 指令中所用的特殊元素 (「SQL Injection」)。CWE-89 稱：「軟體使用源自上游元件之外部影響的輸入構建全部或部分 SQL 指令，但是並未抵消或不正確地抵消了特殊元素，導致將預期的 SQL 指令傳送至下游元件時，這些特殊元素會修改預期的 SQL 指令。」

No Issues

Risky Resource Management - CWE ID 120

執行緩衝區複製時未檢查輸入的大小 (「典型的 Buffer overflow」)。CWE-120 稱：「程式將輸入緩衝區複製到輸出緩衝區時，未確認輸入緩衝區的大小是否小於輸出緩衝區的大小，導致 Buffer overflow。」

No Issues



Risky Resource Management - CWE ID 131

不正確地計算緩衝區大小。CWE-131 稱：「在分配緩衝區時，軟體並未正確計算將使用的大小，這會導致 Buffer overflow。」

No Issues

Risky Resource Management - CWE ID 134

無控制的 Format String。CWE-134 稱：「軟體在 printf-style 功能中使用外部控制的 format string，會導致 Buffer overflow 或資料表示問題。」

No Issues

Risky Resource Management - CWE ID 190

整數溢位或環繞。CWE-190 稱：「若邏輯假設產生的值始終大於原始值，則軟體執行的計算會產生整數溢位或環繞。如此在將計算用於資源管理或執行控制時會引入其他弱點。」

No Issues

Porous Defenses - CWE ID 250

以不需要的權限執行。CWE-250 稱：「軟體執行作業時所用的權限層級高於所需的最低層級，這會產生新的弱點，或放大其他弱點的後果。」

No Issues

Porous Defenses - CWE ID 306

對於重要功能缺少驗證。CWE-306 稱：「對於需要可證實的使用者身分或需要消耗大量資源的功能，軟體不執行任何驗證。」

No Issues

Porous Defenses - CWE ID 307

不正確地限制過多的驗證嘗試。CWE-307 稱：「軟體並未實作充分的措施以防止短時間內出現多個失敗的驗證嘗試，如此導致更容易受到暴力破解攻擊。」

No Issues



Porous Defenses - CWE ID 311

敏感資料缺少加密。CWE-311 稱：「在儲存或傳輸之前，軟體並未加密敏感資訊或重要資訊。」

Password Management		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:303	Sink: java.sql.DriverManager.getConnection() Enclosing Method: queryMasterNode() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.AiEmailResultRptServ.readSqlConfig() In serv/AiEmailResultRptServ.java:580	SCA
serv/AiEmailResultRptServ.java:352	Sink: java.sql.DriverManager.getConnection() Enclosing Method: exportData() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.AiEmailResultRptServ.readSqlConfig() In serv/AiEmailResultRptServ.java:580	SCA
serv/GenAiCallingRptServ.java:333	Sink: java.sql.DriverManager.getConnection() Enclosing Method: queryMasterNode() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.GenAiCallingRptServ.readSqlConfig() In serv/GenAiCallingRptServ.java:553	SCA
serv/GenAiCallingRptServ.java:368	Sink: java.sql.DriverManager.getConnection() Enclosing Method: exportCsvData() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.GenAiCallingRptServ.readSqlConfig() In serv/GenAiCallingRptServ.java:553	SCA
serv/ImportAiResultServ.java:403	Sink: java.sql.DriverManager.getConnection() Enclosing Method: querySqlServer() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.ImportAiResultServ.readSqlConfig() In serv/ImportAiResultServ.java:485	SCA

Porous Defenses - CWE ID 327

使用有漏洞或有風險的加密演算法。CWE-327 稱：「使用有漏洞或有風險的加密演算法將招致無謂的風險，可能會導致敏感資訊暴露。」

Weak Encryption: Insecure Mode of Operation		High
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:281	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/AiEmailResultRptServ.java:500	Sink: getInstance() Enclosing Method: decodeFtpCredential() Source:	SCA
serv/GenAiCallingRptServ.java:286	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/GenAiCallingRptServ.java:473	Sink: getInstance() Enclosing Method: decodeFtpCredential() Source:	SCA
serv/ImportAiResultServ.java:304	Sink: getInstance() Enclosing Method: decryptRsaFile() Source:	SCA
serv/ImportAiResultServ.java:531	Sink: getInstance() Enclosing Method: decodeFtpCredential() Source:	SCA

Insecure Interaction - CWE ID 352

跨網站偽造要求 (CSRF)。CWE-352 稱：「Web 應用程式不會或無法充分確認形式良好、有效、一致的要求是否為提交要求的使用者故意提供的。」

No Issues

Insecure Interaction - CWE ID 434

對上傳含危險類型的檔案未作限制。CWE-434 稱：「軟體將允許攻擊者上傳或傳輸危險類型的檔案，可在產品的環境中自動處理這些檔案。」

No Issues

Risky Resource Management - CWE ID 494

下載程式碼時未執行完整性檢查。CWE-494 稱：「產品從遠端位置下載來源程式碼或可執行檔，然後執行程式碼，但未充分確認程式碼的來源與完整性。」

No Issues



Insecure Interaction - CWE ID 601

URL 重新導向至不可信賴的網站 (「開放式重新導向」)。CWE-601 稱：「Web 應用程式接受使用者控制的輸入，該輸入會指定外部網站的連結，並將該連結用於重新導向。如此會簡化釣魚攻擊。」

No Issues

Risky Resource Management - CWE ID 676

使用可能存在危險的功能。CWE-676 稱：「程式呼叫可能存在危險的功能，若該功能使用不正確，會引入弱點，但是也可以安全使用該功能。」

No Issues

Porous Defenses - CWE ID 732

為關鍵資源指定不正確的權限。CWE-732 稱：「軟體為安全性關鍵資源指定權限時，採用的方式允許非預期的動作執行者讀取或修改資源。」

No Issues

Porous Defenses - CWE ID 759

使用單向雜湊 (無 Salt)。CWE-759 稱：「軟體針對不應是可逆的輸入 (例如密碼) 使用單向加密式雜湊，但是軟體不會同時在輸入中使用 salt。」

No Issues

Porous Defenses - CWE ID 798

使用程式碼硬式編碼的憑證。CWE-798 稱：「軟體包含程式碼寫死的憑證 (例如密碼或加密金鑰)，軟體將這些憑證用於輸入的驗證、對外部元件的輸出通訊，或內部資料的加密。」

No Issues

Porous Defenses - CWE ID 807

在安全性決策中依賴不可信賴的輸入。CWE-807 稱：「應用程式使用的保護機制依賴輸入的存在或輸入的值，但是不可信賴的動作執行者可以採用規避保護機制的方式修改輸入。」

Often Misused: Authentication		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:198	Sink: <code>getLocalHost()</code> Enclosing Method: <code>runProcess()</code> Source:	SCA
serv/AiEmailResultRptServ.java:198	Sink: <code>getHostName()</code> Enclosing Method: <code>runProcess()</code> Source:	SCA
serv/GenAiCallingRptServ.java:192	Sink: <code>getHostName()</code> Enclosing Method: <code>runProcess()</code> Source:	SCA
serv/GenAiCallingRptServ.java:192	Sink: <code>getLocalHost()</code> Enclosing Method: <code>runProcess()</code> Source:	SCA
serv/ImportAiResultServ.java:196	Sink: <code>getHostName()</code> Enclosing Method: <code>runProcess()</code> Source:	SCA
serv/ImportAiResultServ.java:196	Sink: <code>getLocalHost()</code> Enclosing Method: <code>runProcess()</code> Source:	SCA

Risky Resource Management - CWE ID 829

納入源自不可信賴的控制領域中的功能。CWE-829 稱：「軟體從預期控制領域之外的來源匯入、要求或納入可執行功能 (例如程式庫)。」

No Issues

Porous Defenses - CWE ID 862

缺少授權。CWE-862 稱：「動作執行者嘗試存取資源或執行動作時，軟體不執行授權檢查。」

No Issues

Porous Defenses - CWE ID 863

授權不正確。CWE-863 稱：「動作執行者嘗試存取資源或執行動作時，軟體會執行授權檢查，但不會正確執行該檢查。攻擊者可藉此規避預期的存取限制。」

No Issues

